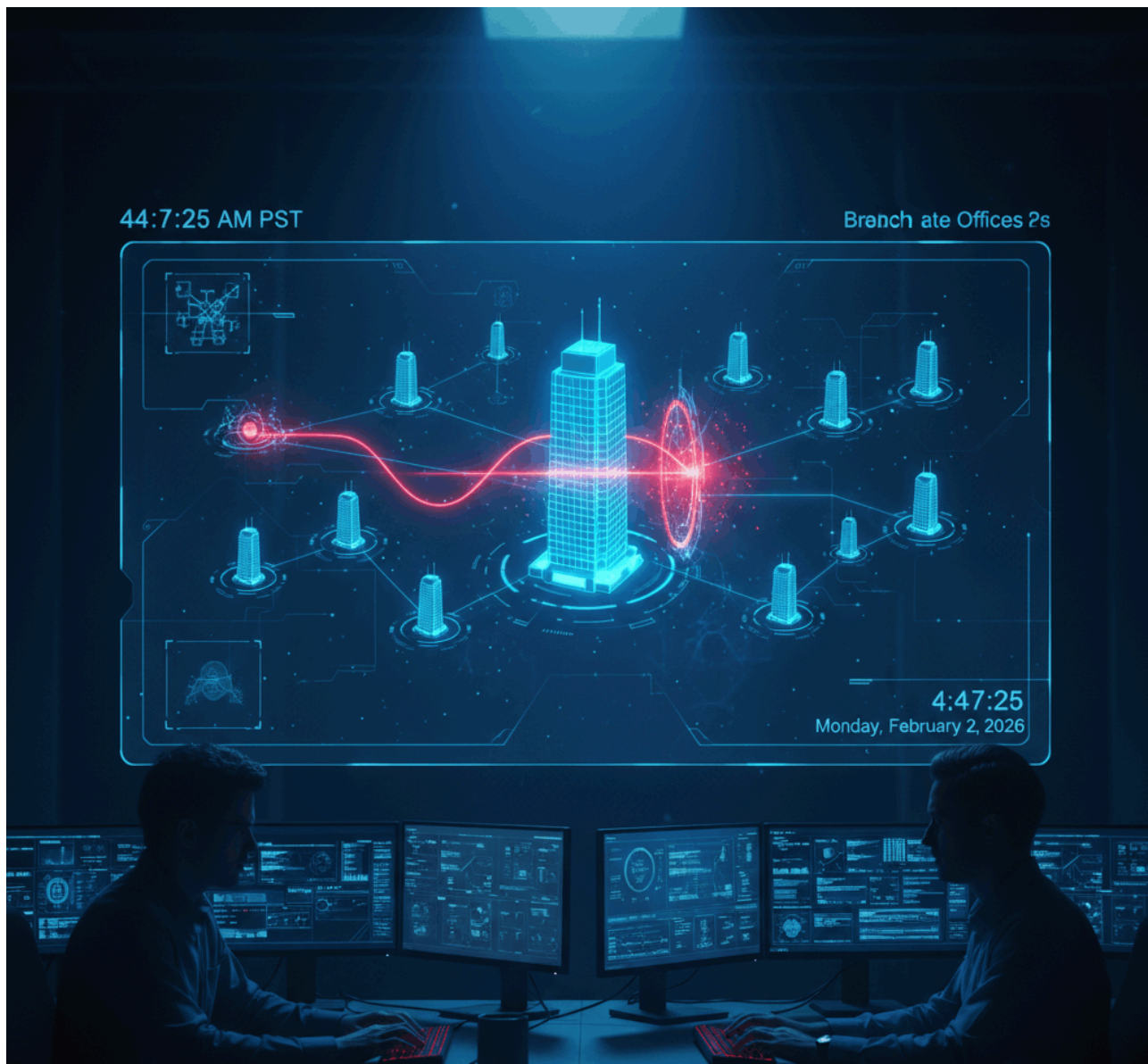


# Полное руководство по защите организационной структуры. Как юрлица, филиалы и подрядчики становятся открытой дверью для хакеров

 [redsec.by/article/polnoe-rukovodstvo-po-zashite-organizacionnoj-struktury-kak-yurlica-filialy-i-podryadchiki-standovyatsya-otkrytoj-dveryu-dlya-hakerov](https://redsec.by/article/polnoe-rukovodstvo-po-zashite-organizacionnoj-struktury-kak-yurlica-filialy-i-podryadchiki-standovyatsya-otkrytoj-dveryu-dlya-hakerov)

Red Teams | 2 февраля 2026



## Почему периметр больше не существует

В эпоху цифровой трансформации классическое понятие «периметра безопасности» окончательно стерлось. Современная корпорация — это не единый замок с высокими стенами, а разветвленная империя, состоящая из десятков юридических лиц, сотен

брендов, тысяч подрядчиков и бесконечной сети филиалов. Атакующие прекрасно это понимают.

Вместо того чтобы штурмовать главные ворота (материнскую компанию), защищенные по последнему слову техники (SOC, EDR, SIEM), хакеры ищут «черный ход». Они атакуют забытый филиал в регионе, незащищенного вендора или маркетинговое агентство, имеющее доступ к вашей CRM.

### Немного отрезвляющей статистики:

- **29%** всех успешных взломов сегодня реализуются через вектор атаки на третьих лиц (Third-Party).
- **30%** нарушений данных в 2025 году начались с этапа разведки (Reconnaissance) цепи поставок.
- **56.4%** организаций столкнулись с компрометацией через партнера, имевшего легитимный доступ к сети.
- **Масштаб проблемы:** Компании, имеющие более 16 филиалов, демонстрируют экспоненциальный рост рисков безопасности.
- **Цепная реакция:** 4.5% взломов происходят через «четвертые стороны» (поставщики ваших поставщиков), что делает атаку практически невидимой для стандартных средств мониторинга.

Главная проблема заключается в **отсутствии видимости**. Согласно исследованиям, **51%** организаций не имеют актуального реестра всех связанных сущностей, имеющих доступ к их данным. Это создает гигантские «слепые зоны» (Blind Spots).

В этой статье мы подробно разберем методологию **Entity Mapping** — систематического картирования организационной структуры. Мы пройдем путь от юридического анализа до технического OSINT, научимся выявлять скрытые связи через DNS и SSL, и построим единую стратегию защиты распределенной инфраструктуры.

## Часть 1. Анатомия айсберга: Типология связанных сущностей

---

Чтобы защитить инфраструктуру, нужно сначала понять её реальные границы. Большинство CISO видят только верхушку айсберга — головной офис и основные дата-центры. Однако под водой скрывается огромный массив связанных сущностей, каждая из которых является потенциальным вектором атаки.

### 1.1. Юридические лица и дочерние компании (Subsidiaries)

---

Это классический пример «островов» в океане корпоративной сети.

**Дочерняя компания** — это отдельное юридическое лицо с собственной регистрацией, находящееся под финансовым контролем или во владении материнской структуры.

#### Специфика угрозы:

Главная опасность «дочек» — **автономия**. Часто они приобретаются в ходе слияний и поглощений (M&A).

- **Разная ДНК:** У них своя история, свои унаследованные IT-системы (Legacy), свои администраторы и, что критично, свои политики безопасности.
- **Maturity Gap (Разрыв зрелости):** Материнская компания может быть на уровне зрелости 5 (Optimized), а купленная «дочка» — на уровне 1 (Initial).
- **Скрытые мосты:** Несмотря на юридическую сепарацию, технически они часто связаны: общие Active Directory трасты, VPN-туннели для обмена отчетностью, общие почтовые шлюзы.

**Вектор атаки "Island Hopping":** Злоумышленники используют стратегию «прыжков по островам». Они компрометируют слабо защищенную дочернюю компанию, закрепляются там, а затем, используя доверенные каналы связи, двигаются латерально (боковое перемещение) в сеть материнской корпорации. Для SOC материнской компании такой трафик часто выглядит легитимным.

## 1.2. Филиалы и отделения (Branches)

---

В отличие от дочерних компаний, филиалы не имеют юридической самостоятельности, но часто обладают пугающей *технической* самостоятельностью.

Представительства, географически удаленные от центра, часто с локальной IT-поддержкой.

#### Специфика угрозы:

- **Shadow IT (Теневые ИТ):** Филиал в условном Владивостоке может решить, что корпоративная CRM слишком медленная, и начать вести базу клиентов в Google Sheets или на локальном NAS-сервере, выставленном в интернет.
- **Кадровый фактор:** В филиалах часто нет выделенного офицера безопасности. IT-функции выполняет «приходящий админ» (эникейщик), который не знает и не соблюдает корпоративные стандарты.
- **Недокументированные связи:** Связь филиала с центром часто настраивается ситуативно и не документируется в CMDB.

**Пример сценария:** Сотрудник филиала использует неофициальный облачный сервис для конвертации PDF. Сервис оказывается вредоносным. Через компьютер сотрудника шифровальщик попадает в корпоративный VPN.

### 1.3. Бренды и подразделения (Brands & Divisions)

---

Маркетинг часто бежит быстрее безопасности. Компании запускают десятки промо-сайтов, лендингов и суббрендов.

Торговые марки, работающие под единым управлением.

#### Специфика угрозы:

- **Сертификатный хаос:** Использование Wildcard-сертификатов (\*.brands.com) на всех проектах сразу. Компрометация приватного ключа на одном забытом промо-сайте ставит под удар шифрование всех остальных ресурсов.
- **Единая точка отказа:** Часто у разных брендов одна служба безопасности. Перегрузка команды инцидентом на одном бренде оголяет тылы других.

**Судебный прецедент:** Дело *Aaron's Inc.* показало, что корпоративный центр может нести юридическую ответственность за нарушения конфиденциальности (шпионское ПО на ноутбуках), произошедшие в сети франчайзи, если центр имел техническую возможность контроля.

### 1.4. Франшизы (Franchises)

---

Самый сложный для контроля сегмент.

Независимые владельцы, работающие под вашим брендом, но на своем оборудовании.

#### Специфика угрозы:

- **Нулевая видимость:** Франчайзер часто не имеет права (или технической возможности) ставить свои агенты EDR или сканеры уязвимостей на оборудование франчайзи.
- **Зоопарк технологий:** В одной точке может стоять современный iPad, в другой — Windows XP для кассы.
- **Репутационный риск:** Посетитель ресторана не знает, что точку держит ИП Иванов. Если у него украдут данные карты, виноват будет Глобальный Бренд.

**Кейсы:** Крупные взломы POS-терминалов в сетях *Wendy's*, *Dairy Queen*, *Jimmy John's* произошли именно через компрометацию инфраструктуры отдельных франчайзи, которая затем позволила атаковать централизованные платежные шлюзы.

### 1.5. Партнёры и цепочка поставок (Supply Chain)

---

Это «мягкое подбрюшье» любой корпорации.

MSP (Managed Service Providers), интеграторы, разработчики, клининг, охрана — все, кто имеет доступ к сети.

### Типы и риски:

- **MSP (Провайдеры управляемых услуг):** Имеют ключи от царства — административный доступ к серверам сотен клиентов. MSP присутствуют в цепочке атаки в **29%** случаев.
- **Интеграторы ПО:** Часто требуют постоянный VPN-туннель или учетную запись с правами Domain Admin «для поддержки».
- **Каскадный эффект:** Взлом одного крупного игрока (как SolarWinds или Kaseya) автоматически компрометирует тысячи его клиентов, включая правительственные агентства и корпорации из списка Fortune 500.

## Часть 2. Методология выявления: OSINT-разведка корпоративной паутины

---

Как найти то, что вы не знаете? Необходимо использовать методы OSINT (Open Source Intelligence), которыми пользуются сами хакеры. Мы ищем цифровые отпечатки, которые связывают разрозненные активы в единую картину.

### 2.1. Доменная разведка: WHOIS и Reverse WHOIS

---

Регистрационные данные доменов — это первое звено в цепочке расследования.

**Принцип:** Даже если компания старается скрыть свои активы, администраторы часто ленятся. Они используют один и тот же email («admin@corp.com») или номер телефона для регистрации сотен доменов: от основного сайта до тестовых серверов.

#### Что искать (Pivot Points):

- **Registrant Organization:** Официальное название юрлица.
- **Registrant Email:** Золотая жила для Reverse WHOIS.
- **Technical Contact:** Часто личный email сисадмина, который «по-быстрому» поднял домен.

#### Инструментарий:

Для CLI (Command Line Interface) любителей:

```
# Прямой запрос  
$ whois example.com
```

```
# Запрос к конкретному серверу (например, для IP)  
$ whois -h whois.arin.net IP.ADDRESS
```

Для автоматизации и масштабирования:

- **Whoxy.com / API:** Позволяет делать исторические и обратные поиски.
- **DNSlytics / SecurityTrails:** Визуализируют связи.

### Пример скрипта для автоматизации:

```
# Пример концептуального использования API Whoxy для поиска всех доменов компании
$ whoxym -o "Company Name" > domains.txt
```

*В реальной практике, анализ компании уровня Upwork через такой метод может выявить более 1000 доменов, о существовании половины из которых отдел ИБ может не подозревать.*

## 2.2. Сертификатный анализ: SSL/TLS как маркер

---

SSL-сертификаты рассказывают историю инфраструктуры лучше, чем любая документация.

### Certificate Transparency (CT Logs):

Это публичные логи всех выпущенных сертификатов. Если ваш админ выпустил сертификат для dev.secret-project.company.com, эта запись навсегда останется в CT логах, даже если домен закрыт фаерволом.

### Ключевые поля для анализа:

- **Subject CN (Common Name):** Основное имя.
- **SAN (Subject Alternative Names):** Список всех доменов, защищенных этим сертификатом. Часто в одном сертификате можно найти corp.com, corp-shop.com и corp-internal-vpn.com, что сразу выдает связь брендов.
- **Issuer:** Если у разных доменов сертификаты выданы одним и тем же внутренним CA (Certificate Authority), это 100% связь.

### Инструменты разведки:

Использование поисковика Censys:

```
services.tls.certificates.leaf_data.names: "company.com"
services.tls.certificates.leaf_data.issuer.organization: "COMPANY"
```

Работа с CT логами через терминал:

```
curl "https://crt.sh/?q=%25company.com&output=json" | jq
```

Поиск через Shodan по организации-владельцу:

```
ssl.cert.subject:"/O=Company Name/"
ssl.cert.serial:"XXXXXXX"
```

## 2.3. Инфраструктурный след: DNS, IP и ASN

---

Сетевой уровень дает наиболее точные технические подтверждения связей.

**DNS Enumeration:** Анализ DNS записей позволяет выявить не только серверы, но и используемые SaaS-сервисы.

```
# Получение всех записей (может быть заблокировано, лучше запрашивать типы отдельно)
dig example.com ANY
```

```
# Анализ почтовой инфраструктуры
```

```
dig example.com MX
```

```
# Анализ делегирования и алиасов
```

```
dig example.com CNAME
```

```
# Текстовые записи (верификация владения)
```

```
dig example.com TXT
```

- **CNAME** часто указывает на облака (AWS ELB, Azure) или CDN (Cloudflare).
- **TXT** записи раскрывают вендоров: google-site-verification, atlassian-domain-verification.
- **NS** записи показывают, кто управляет зоной (собственный DNS или аутсорс).

**IP и ASN (Autonomous System Number):** Крупные организации имеют свои блоки IP-адресов и номера автономных систем.

```
# Определение ASN по IP
```

```
$ whois 203.0.113.1
```

```
# Ответ: AS12345 Organization: ACME Corp
```

```
# Обратный поиск всех префиксов (сетей), принадлежащих этой AS
```

```
$ whois -h whois.radb.net "!as12345"
```

Поиск в Shodan по ASN (asn:AS12345) позволяет найти все устройства компании, торчащие в интернет, даже если у них нет доменных имен.

## 2.4. Цифровые отпечатки: Analytics & Tracking IDs

---

Это метод «пассивной дактилоскопии». Веб-разработчики вставляют одинаковые скрипты аналитики на все сайты холдинга для агрегации статистики.

**Что искать в исходном коде:**

```
<script>
ga('create', 'UA-12345678-1', 'auto');
</script>
```

ID вида UA-XXXXXXX или GTM-контейнеры, Facebook Pixel ID, AdSense ID уникальны.

Используя сервисы типа **BuiltWith** или **SecurityTrails**, можно найти все сайты в

интернете, использующие тот же ID. Это часто вскрывает забытые лендинги или сайты филиалов, которые создавались маркетингом в обход ИТ.

## 2.5. Корпоративная разведка и соцсети

---

Не стоит забывать про «человеческий фактор» и открытые реестры.

- **LinkedIn:** Анализ профилей сотрудников. Если человек пишет «System Administrator at ACME Group (serving Brand X, Brand Y)», он прямо указывает на связь сущностей. Вакансии часто раскрывают стек технологий и структуру подчинения.
- **Корпоративные реестры (ЕГРЮЛ, OpenCorporates):** Позволяют юридически подтвердить аффилированность, найти дочерние компании и бенефициаров (Beneficial Owners).

## Часть 3. Векторы атак: Как это используется против вас

---

Почему мы тратим столько времени на составление карты? Потому что именно по этой карте пойдет атака.

### 3.1. Shadow IT: Бомба замедленного действия

---

Теневое ИТ — это системы, внедренные подразделениями без ведома CIO/CISO. Это SaaS-приложения (Slack, Trello, Figma), файлообменники, тестовые серверы. **Риск:** Они не обновляются, не мониторятся SIEM, не имеют MFA. Это открытая дверь, о которой охрана просто не знает.

### 3.2. Maturity Gap: Атака на слабое звено

---

В холдинге всегда есть дисбаланс.

- **Уровень 5 (Головной офис):** SOC 24/7, Red Teaming, Zero Trust.
- **Уровень 1 (Региональный склад):** Роутер D-Link с паролем admin/admin и Windows 7. Атакующий всегда пойдет через склад. Компрометация склада дает доступ в VPN, который ведет в головной офис.

### 3.3. Island Hopping (Прыжки по островам)

---

Это классическая тактика APT-группировок.

- **Вход:** Фишинг на сотрудника франчайзи.
- **Закрепление:** Установка RAT (Remote Access Trojan).
- **Разведка:** Поиск связей с «большой землей» (общие сетевые папки, доступ к ERP через Citrix).

- **Прыжок:** Использование легитимного канала для атаки на материнскую компанию.

### 3.4. Угроза N-го порядка (Fourth-Party Risk)

Ваш подрядчик тоже имеет подрядчиков. *Пример:* Вы наняли разработчика. Разработчик использует облачную IDE. Облачная IDE использует уязвимую библиотеку логирования (Log4j). Взлом библиотеки → Взлом IDE → Кража исходного кода вашего разработчика → Взлом вас.

## Часть 4. Создаем "Карту Связей": Практический фреймворк

Перейдем от теории к документации. Результатом вашей работы должен стать документ **"Organization Entity Map"**.

### 4.1. Реестр Юридических Лиц

Это база данных всех legal entities.

| Entity ID | Name            | Type       | Jurisdiction | Owner (%)   |
|-----------|-----------------|------------|--------------|-------------|
| E001      | ACME Corp       | Parent     | USA          | -           |
| E002      | Sub Europe GmbH | Subsidiary | Germany      | E001 (100%) |
| E003      | Brand Asia Ltd  | Division   | Singapore    | E001 (100%) |
| E004      | Franch DE       | Franchise  | Germany      | Independent |
| E005      | MSP Tech        | Vendor     | Poland       | External    |

### 4.2. Инвентаризация Активов (Asset Mapping)

Привязка технических активов к юридическим лицам.

| Entity | Domain       | IP/ASN          | Certificate Status | Risk Level |
|--------|--------------|-----------------|--------------------|------------|
| E001   | acme.com     | 203.0.113.0/24  | Wildcard (*)       | MANAGED    |
| E001   | *.acme.com   | AWS (Dynamic)   | Valid              | MANAGED    |
| E002   | subeu.de     | 198.51.100.0/24 | Separate           | MONITORED  |
| E003   | brandasia.cn | Alibaba CDN     | Expired?           | HIGH       |
| E004   | franch.de    | 91.x.x.x (DSL)  | Missing            | CRITICAL   |

### 4.3. Матрица Рисков (Risk Heatmap)

---

Не все сущности одинаково опасны. Оцените их по критичности для бизнеса и зрелости ИБ.

| Entity     | Criticality | Maturity (1-5) | Public Exposure | Risk Score           |
|------------|-------------|----------------|-----------------|----------------------|
| ACME Corp  | CRITICAL    | 4              | Low             | 7/10 (Fair)          |
| Brand Asia | MEDIUM      | 2              | High            | 3/10 (Poor)          |
| Franch DE  | MEDIUM      | 1              | High            | <b>2/10 (URGENT)</b> |
| MSP Tech   | CRITICAL    | 4              | Medium          | 6/10 (Fair)          |

*Примечание: Высокий риск у Франчайзи (Franch DE) требует немедленного вмешательства, так как зрелость низкая, а экспозиция высокая.*

## Часть 5. Валидация: Исключаем ложные срабатывания

---

Автоматический поиск даст много шума. Как убедиться, что найденный домен реально ваш?

### Чеклист валидации:

- **Домен:** Registrant Organization в WHOIS совпадает с вашим юрлицом?
- **DNS:** Есть ли TXT-записи, которые вы сами вносили? Указывают ли MX-записи на ваш почтовый шлюз?
- **SSL:** Выдан ли сертификат на ваше имя? Присутствует ли домен в SAN вашего основного сертификата?
- **Контент:** Есть ли на сайте ваши логотипы, адреса офисов, телефоны?
- **Бизнес-связь:** Подтверждается ли владение через финансовые отчеты или реестры?

## Часть 6. Стратегия защиты: Управление хаосом

---

Когда карта составлена, пора строить оборону.

### 6.1. Жизненный цикл управления третьими сторонами (TPRM)

---

- **Onboarding:** Никакого доступа без аудита безопасности (Security Assessment). Проверка наличие SOC 2 или ISO 27001 у вендора.
- **Контрактация:** Включите в договор SLA на установку патчей и обязательство уведомить вас о взломе в течение 24 часов. Право на аудит (Right to Audit).

- **Мониторинг:** Используйте сервисы типа *SecurityScorecard* или *BitSight* для непрерывного скоринга безопасности ваших партнеров.
- **Offboarding:** При расторжении контракта — немедленный отзыв всех доступов и удаление данных.

## 6.2. Сегментация и Zero Trust

---

Если вы не можете контролировать безопасность партнера, контролируйте его доступ.

- **Least Privilege:** Вендор получает доступ только к одной папке или порту.
- **JIT (Just-in-Time):** Доступ выдается на 2 часа для проведения работ, затем автоматически отзывается.
- **Сетевая изоляция:** Подрядчики должны находиться в отдельном VLAN или DMZ. Никогда не пускайте их в плоскую сеть с контроллерами домена.

## 6.3. Работа с Shadow IT

---

Политика «Запретить всё» не работает. Люди найдут обход. Вместо этого:  
**Обнаружить → Оценить риски → Легализовать (взять под контроль) или Заменить безопасным аналогом.**

## Часть 7. Инструментарий профессионала

---

Сводка команд и инструментов для вашей работы.

### Базовый набор (CLI):

```
# WHOIS разведка
whois example.com
whois -h whois.arin.net 203.0.113.1
```

```
# DNS анализ
dig example.com ANY
dig -x 203.0.113.1
```

```
# Поиск поддоменов (Subdomain enumeration)
subfinder -d company.com
puredns resolve subdomains.txt
```

```
# Работа с сертификатами
curl "https://crt.sh/?q=%25company.com&output=json"
```

### Продвинутые платформы:

- **Shodan/Censys:** Глобальный поиск устройств и сертификатов.
- **Maltego:** Визуализация связей (графы).

- **RiskRecon / Panorays:** Автоматизированная оценка рисков вендоров.

**Entity Mapping** — это не разовый аудит, который можно сделать и положить на полку. Организационная структура живая: компании покупаются и продаются, подрядчики меняются, бренды запускаются.

Ваша карта устареет в тот момент, когда вы закончите её рисовать. Поэтому процесс должен быть цикличным:

- **Ежемесячно:** Обновление технических активов (домены, IP).
- **Ежеквартально:** Переоценка рисков вендоров.
- **При событиях (M&A):** Немедленная интеграция новых сущностей в карту.

Помните: атакующие уже составили карту вашей организации. Они знают ваши слабые филиалы и забытые домены. Вопрос лишь в том, знаете ли о них вы, и успеете ли вы закрыть брешь до того, как через нее начнется вторжение.

*Материал подготовлен на основе актуальных методик управления поверхностью атаки (EASM) и стандартов безопасности цепочек поставок.*

**Как вам статья?**

---